

Proposal for Hack the Box Challenge: Under the Web (PWN)

Project Team -2

Divya Sidduluru (11822383)

Manohar Badhanaveni (11822756)

Ruthiksha Reddy Yenugu (11714976)

Priya Dhanne (11828574)

1. Chosen Box: Under the Web (PWN) we have selected the challenge "Under the Web" in the PWN category as this consists of exploiting a compromised web application for a variety of security exploits and vulnerabilities.

2. Reason to Select: We are selecting this challenge to refine our skills in loopholed web applications and exploits. It is one of the significant avenues in building cybersecurity expertise. "Under the Web" renders a realistic environment with a scope for implementing these skills, which is of vast necessity for my development as a network security professional.

3. Plan for Solving the Box

- **Initial Reconnaissance** Use Nmap to perform a port scan and service enumeration against it. Employ WhatWeb and BuiltWith to grab technologies used by the web application. Check back and run some exposed files and directory scans for sensitive information.
- **Enumeration** Analyze web traffic with Burp Suite for hidden endpoints. Use Dirbuster for directory traversal to find hidden or unprotected resources. Conduct vulnerability tests like SQL injection, XSS, and CSRF with both manual and automated approaches.
- **Exploitation** Run SQL injection attacks through SQLmap if they exist with Postgresql, Oracle, or MYSQL. Deploy XSS payloads to check for script execution vulnerabilities. Try a brute force attack on the logging panels with Hydra to compromise weak passwords.
- **Privilege Escalation** Look into server and application configurations for possible misconfigurations or obsoleted components that can be exploited. Use any available admin interfaces to try further exploitation and escalate privileges.
- **Post-Exploitation** Document the stages of exploitation while capturing evidence of the compromised systems. Determine what data can be extracted in addition to what was originally gained through exploitation and security evaluation.

4. Expected Challenges

- Working around sophisticated security setups like WAFs or CSPs.
- Real-time strategy shifts against custom security solutions.
- Complex exploitation chains where multiple vulnerability exploits must succeed.

5. Tools & Resources

- Scanning and Analysis: Nmap, WhatWeb, BuiltWith, Burp Suite
- Exploitation: SQLmap, Metasploit, Hydra
- Enumeration: Dirbuster, Nikto
- Documentation: CherryTree, notes organization.